Win10停服叠加CLFS提权漏洞加剧风险，奇安信以第三代技术克服传统防护瓶颈

时间：2025-10-16　作者：奇安信集团

10月14日，微软Windows10正式终止服务的钟声如期敲响，微软官方将不再提供技术支持、软件功能更新或安全更新，并提醒继续使用该系统会增加感染病毒和恶意软件的风险。然而据Canalys数据统计，全球仍有超5亿台活跃设备运行该系统，其中我国政府、能源、医疗、金融、交通等多个重要行业领域占比显著。

奇安信安全专家表示，停服意味着微软彻底终止安全补丁更新与漏洞修复服务，而这一变动将让近年来备受关注的CLFS（CommonLogFileSystem）提权漏洞风险呈几何级爆发。

Win 10停服叠加CLFS漏洞风险，超1亿设备成黑客目标

本周最大的新闻莫过于Windows 10各版本于10月14日停止更新。停服后用户只能通过购买“扩展安全更新（ESU）”在一年内获取部分关键补丁。下表汇总了主要版本的发布时间和服务终止时间（根据公开信息整理）：

版本	发布时间	支持终止（家庭/专业版）	特别说明
1507	2015-07-29	2017-05-09	首个公开版本
1511	2015-11-10	2017-10-10	体验更新
1607	2016-08-02	2018-04-10 (家庭/专业版)	企业版支持更长
1803	2018-04-30	2019-11-12	启用时间线功能
21H2	2021-11-16	2023-06-13	最后一个长期支持版
22H2	2022-10-18	**2025-10-14**	Windows 10 最后一个版本

来自英国Quest IT Support 网站的宣传图，形象地描绘了Windows 10自2015年发布至2025年停服的历程，并提醒企业“Windows 10 即将走到生命终点”。

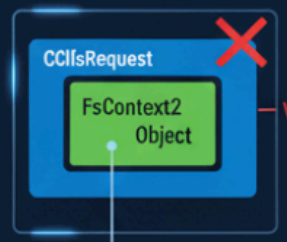
图中墓碑显示Windows 10的“出生日期”——2015年7月29日，以及停服日期 2025年10月14日，强调停服后企业需要尽快规划升级或采取补救措施。”。

如今，Windows 10停服给用户带来第一个重大风险，就是CLFS提权漏洞。

CVE-2025-29824: Windows CLFS UAF Zero-Day

INITIAL STATE

The Opuvs Creale MarsalingArea
Mass of Fanleumed.

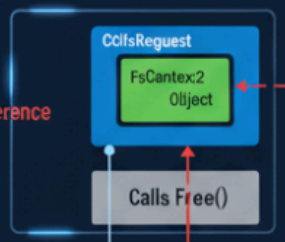


Valid Refeeict: 1

IRP_MJ_CLEANUP

2. PREMATUARE REEMBRE FREE (UAF)

Ref Cuunt Erer > Attacker Attacler
Datlet Contnalbate.



FREED MEMORY

Fs:Conez2 freed too early

RACE CONDITION / UAF

Ref Count Erer > Attacker Attater

TIME-OF-CHECK TO TIME OF-USE WINDOW

Attacker
Re-uss
Freed Memory

Notifcations

Danglap Allocation

The tle s sune odxxifra geat fnor ne fong
tnuisimg or tbeestate Nre d aad yiond heabted
tfiuur.

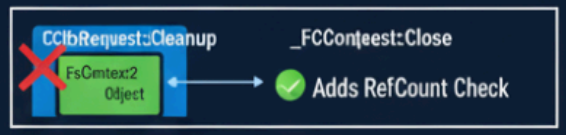
TORE FECCCUPATION

Dectlos Fanster

SYSTEM

Arbitrary
Kernel Wi–
> SYSTEM
PRIVERIGES

MICROSOFT PATCH



Fix: Move Free to Close, Add RefCount

Exodus INTELLIGENCE

CLFS作为Windows系统核心日志文件系统，负责记录系统关键操作与进程状态，其权限控制直接关联系统底层安全。

此前披露的CLFS提权漏洞可允许低权限用户通过构造恶意日志请求，绕过系统权限校验机制获取管理员权限，进而植入勒索软件、窃取敏感数据或实施远程控制，具有极大的危害性。

在Win10仍受官方支持时，微软可通过月度安全更新修复此类漏洞，但停服后，这道关键防线彻底消失。

更严峻的是，约20%的Win10设备因硬件限制无法升级至Win11，超1亿台设备沦为“安全孤岛”，成为黑客攻击的理想目标。

风险的加剧还源于漏洞情报的断供危机。近期微软调整“主动防护计划”，停止向中国网络安全公司发送漏洞预警情报，使得国内厂商难以提前构建防御屏障。

对于CLFS这类核心系统漏洞，攻击者往往会利用情报差发起精准攻击。2024年全球已披露操作系统高危漏洞超3200个，停服后的Win10设备将直接暴露于这些威胁之下，相当于向黑客敞开了大门。

美国消费者组织PIRG高级主管NathanProctor直言，Windows10支持的终结“对消费者和环境都将是一场灾难”，而从安全视角看，这场灾难的核心正是漏洞防护体系的崩塌。

传统防护困局：特征库模式难抵无补丁时代

面对CLFS提权漏洞这类高危威胁，依赖传统防护手段的政企机构正陷入前所未有的被动。当前许多企业仍依赖传统防病毒软件作为主要防护工具。

但业内研究指出，传统以文件信任关系为核心，难以检测因为操作系统停服导致的利用。SentinelOne的分析指出，传统杀毒常见局限包括：

首先是依赖特征库。特征库依赖的致命缺陷首先体现在“滞后性”，传统病毒防护主要通过预定义特征检测恶意文件，对新变种或文件无关的攻击（如脚本、内核漏洞利用）识别能力弱。然而CLFS提权漏洞的攻击手段可快速变种——攻击者只需轻微修改攻击载荷结构，就能绕过特征库检测。

其次是无法查杀系统文件。绝大部分客户的安全要求都是优先保障业务，这时当操作系统程序出现漏洞，无法通过对操作系统进程的关停、对操作系统进行文件查杀解决安全问题。

此外，自动化响应能力的缺失则让防护雪上加霜。多数企业处理安全事件仍高度依赖人工操作，从日志收集、漏洞验证到恶意文件隔离，整个过程可能耗时数周。而CLFS提权漏洞的攻击从成功入侵到完成权限提升仅需数分钟，人工响应的滞后性使得攻击者有足够时间扩大攻击范围，更加大了漏洞的破坏性。

可见，面对CLFS等内核漏洞利用链，仅靠传统终端安全能力难以应对补丁停止后的0day漏洞。

天狗引擎破局：第三代技术重构漏洞防护逻辑

当传统防护在CLFS提权漏洞等威胁面前束手无策时，奇安信发布的以第三代安全技术为核心的天狗漏洞攻击防护引擎，为Win10停服提供了破局之道。该引擎采用了全新指令控制流检测技术，摆脱了传统安全技术对文件、流量、数据、行为等特征的依赖，与人工智能、机器学习技术深度结合，可从更底层实现对已知或未知漏洞利用攻击的安全防护，提供了不同于传统防护的核心优势：

指令流级检测与控制流监控：天狗在内存层面分析指令流与系统调用序列，识别堆喷射、释放、重用和越界写等异常模式，在关键指令执行前即进行阻断。对于CLFS类UseAfterFree利用链，天狗能在覆盖内核令牌前检测到异常写入并阻止提权。

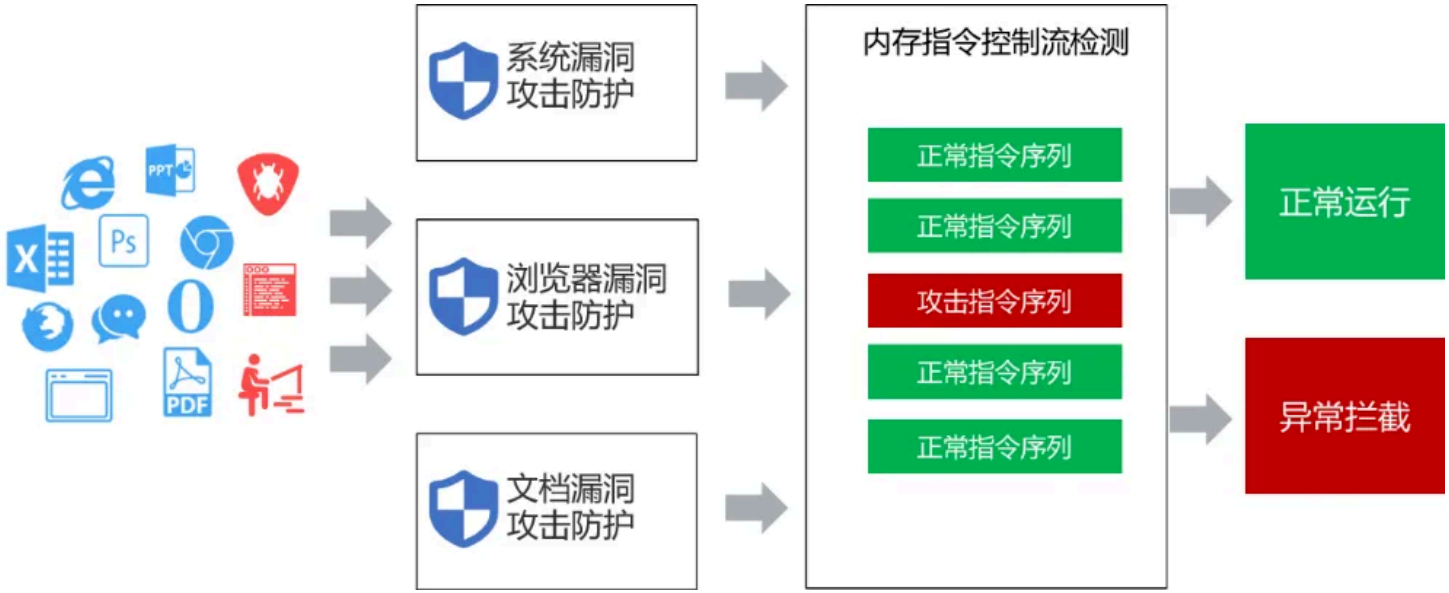
与天擎联动形成“检测→阻断→响应”闭环：天狗可与奇安信终端安全平台协同，当检测到内核利用行为时，自动隔离主机、回滚恶意修改并生成补丁工单，缩短企业响应时间。

覆盖补丁空窗期：在 Windows 10停服后，企业可能无法快速升级全部终端或采购ESU。天狗通过内存级防护弥补补丁缺失的风险，提供“零补丁防护”能力，保证系统在过渡期仍能抵御内核级利用。

成熟的实战验证：目前天狗引擎已在政企、金融和大型活动保障等场景中部署，经过百万级终端验证，具备高检测率和低误报率。在补丁发布前的漏洞利用检测和拦截能力经多方评测认可。

奇安信天擎Win10停服方案已集成天狗引擎

针对Windows停服场景和CLFS提权漏洞威胁，奇安信推出天擎Win10停服专项安全方案，集成了第三代安全技术——天狗漏洞攻击防护引擎，可实现“不换系统、不打补丁、不频繁升级”前提下的安全防护，为政企用户筑牢终端防线。



集成了第三代安全技术—天狗漏洞攻击防护引擎之后，天擎可以为客户提供以下几方面的功能优势：

1、首先是一体化安全防护，实现漏洞攻击全生命周期可视管理。

新功能实现了天擎一体化安装、部署、管理，与天擎同一进程，升级开启授权即可试用。实现漏洞攻击全生命周期可视化管理（攻击溯源、载荷分析、策略联动），运维效率提升3倍。

2、其次是高危窗口期实时拦截，实现黄金72小时攻防

针对第二重风险，在漏洞补丁发布至修复的空档期，基于指令流动态分析，毫秒级识别利用漏洞进行攻击等行为，攻击阻断率＞99.5%。

3、最后是智能拦截高级威胁，实现全链路精准防护。

利用内存指令流检测技术，实时监控终端执行指令，精准发现包括0Day/NDay发起的各种漏洞攻击，构建从攻击识别、实时拦截到风险溯源的全链条防护体系，最大限度降低因攻击导致的系统中断和数据泄露风险。

值得一提的是，集成漏洞攻击防护模块的天擎，可实现零打扰防护关键系统，为业务连续性提供保障。针对金融交易系统、制造业生产线等不可停机场景，防护进程资源占用＜1%，性能影响近乎为零。同时支持企业级敏捷部署，分钟级覆盖万级终端。通过天擎统一管控平台，一键同步防护策略，客户可以无感升级使用。

结语：

Windows 10 即将退役，停服后的风险不仅在于失去新功能，更在于失去官方安全修补。历史证明，CLFS等内核漏洞能被快速武器化，通过复用堆布局、释放与重用等技巧实现本地提权。传统杀毒软件由于缺乏内存级监控和行为分析，难以抵御补丁停止后的高危漏洞攻击。

因此，企业在规划Windows 10升级或迁移的同时，应部署以内存指令序列检测的终端安全产品，如集成天狗引擎的新版天擎，它能够在补丁发布之前发现并阻止内核利用，为停服后的终端提供一道关键屏障。只有通过技术和管理的双重措施，才能在操作系统生命周期终结时保障业务持续和安全。